방어에 14억 쓰는데 커피 한잔값에 뚫려…'초저가 AI해커'의 습격

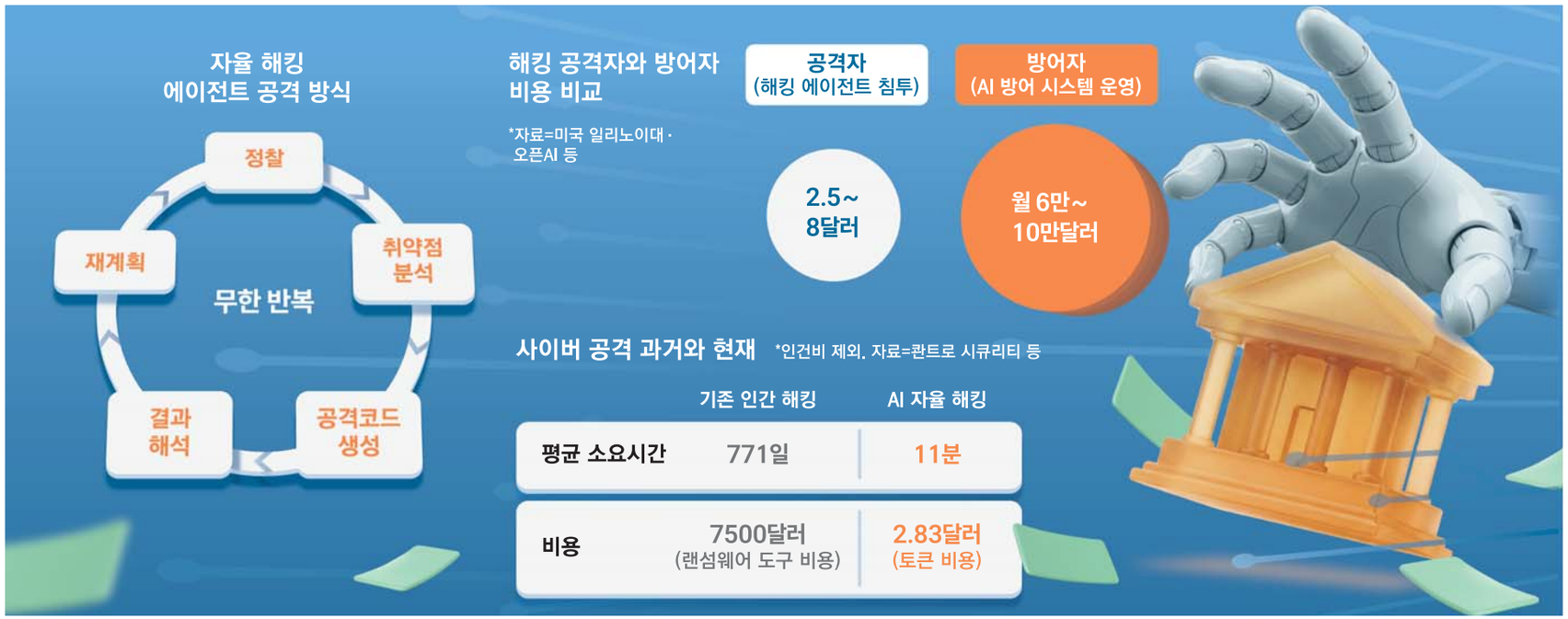
〈미국 기업 연평균 AI보안비용〉

AI가 흔든 '해킹 비용의 룰'

수개월·수억원 들었던 해킹
AI도입 후엔 단 11분, 2.83弗
허위 버그신고로 개발자 교란

성벽 쌓기식 방어는 이제 끝
내부망 사용자 매번 검증하는
AI활용 '제로 트러스트' 시급

금융당국, 공격IP 28개로 특정
미·중·베트남 국적 우회 공격



르지 않지만 공격비용이 급격히 낮아지면서 공격 횟수를 엄청나게 늘릴 수 있게 됐다"며 "앞으로 전방위적으로 해킹 공격이 더 늘어날 것"이라고 전망했다.

◆ 커피 한잔 값에 뚫린 보안망

6일 정보기술(IT) 업계에 따르면 단돈 몇 달러짜리 AI 에이전트가 밤낮없이 기업 방어망에 침투하는 '초저가 해킹' 시대가 현실화했다.

미국 보안 연구기관 콴트로 시큐리티의 최신 보고서에 따르면 자율 AI 에이전트가 시스템의 취약점을 스스로 찾아내 침투 가능한 공격코드를 완성하는 데 걸린 시간은 평균 11분에 불과했다. 이때 투입된 클라우드 연산 비용(토큰 비용)은 단 2.83달러였다.

이 같은 비용 하락은 불과 수년 전만 해도 상상하기 어려웠다. 과거 다크웹 시장에서 거래되던 랜섬웨어 패키지 도구는 7500달러나 했다. 이는 초기 구매 비용일 뿐 최소 수개월간 이어지는 인간 해커들의 인건비 등을 감안하면 실제 비용은 수억 원을 훌쩍 넘어섰다. 그러나 AI 에이전트가 고급 인력을 대체하면서 해킹에 필요한 '인건비 장벽'이 사실상 0원에 수렴하게 됐다.

반면 방어자 쪽은 정반대다. 방어도 AI로 하면 비용이 줄지 않겠냐는 통념과 달리 실제 방어에 AI를 도입한 기업들의 보안 예산은 기하급수적으로 늘고 있다. 비용이 늘어나는 가장 큰 원인은 방대해진 데이터 양과 인프라 비용이다. 공격용 AI는 웹페이지 코드 수백 줄만 읽으면 되지만, 방어용 AI는 사내 방화벽, 웹 서버, 직원 PC에서 쏟아지는 초당 수만 건에 달하는 접속 로그를 24시간 실시간으로 분석해야 한다. 이를 상용 거대언어모델(LLM)에 입력할 경우 토큰 비용이 하루에도 수천만 원에 달한다는 게 보안업계 분석이다. 실제 오픈AI와 가트너 등이 분석한 보안관제 총 소유비용에 따르면 미국 중대형 기업들의 AI 보안관제 유지 비용은 평균 연간 100만달러(월 평균 약 8만3000달러)에 달한다.

◆ 보안업계 "방어 패러다임 바꿔야"

보안 전문가들은 과거처럼 '성벽(네트워크 경계)을 높게 쌓으면 안전할 것'이라는 외곽 방어 중심의 패러다임은 완전히 수명을 다했다고 진단한다. 이제 사이버 보안의 중심축은 '제로 트러스트'(완전히 뚫릴 것으로 가정하고 내부망을 검증하는 모델)로 이동하고 있다.

기존 방화벽이 외부 침입을 막는 성벽 역할에 치중했다면, 제로 트러스트는 내부망에 들어온 사용자라 할지라도 네트워크를 세분화하고 권한을 최소화해 매 단계 신원을 재검증하는 방식이다. 성벽이 뚫릴 수 있다고 전제하고, 한 시스템이 뚫리더라도 핵심 자산망으로 이동하지 못하도록 권한을 쪼개는 망 미세 분리(마이크로 세그먼테이션) 구축이 기본이라는 게 전문가들의 공통된 제언이다.

이재웅 한국IBM 사이버 시큐리티 서비스 총괄은 "프런티어 AI로 기존에 알지 못했던 취약점까지 빠르게 드러나면서 패치와 대응 과정에서 병목이 발생하고 있다"며 "우선 조직별 취약 지점을 파악해 단계적으로 AI 방어 체계를 구축해야 한다"고 말했다.

최고경영자(CEO)의 보안 인식 전환도 시급하다. 보안 투자를 지출로만 볼 게 아니라 AI 시대 기업의 존폐를 가르는 핵심 투자로 인식해야 한다는 것이다. 보안업계 관계자는 "보안 사고가 터지면 수백억 원의 과징금 부과는 물론 고객 신뢰가 회복 불가능한 수준으로 무너진다"고 지적했다.

◆ 인터넷은행도 공격 시도

한편 이날 금융권에 따르면 최근 시중은행들을 공격한 IP 중 일부는 올해 초부터 카카오뱅크, 케이뱅크, 토스뱅크 등 인터넷전문은행들의 서버에도 접근을 시도했던 것으로 나타났다.

이는 금융당국이 개인정보가 유출된 금융사(신한·KB국민·하나·BNK부산은행, 예가람·웰컴저축은행, 현대캐피탈)를 공격하는 데 사용된 IP를 전 금융권에 공유한 뒤 점검하도록 한 결과 발견된 사항이다.

금융당국은 이번 금융권 연쇄 해킹에 사용된 IP를 총 28개로 특정했다. 소재 지역은 미국, 일본, 홍콩(중국), 싱가포르, 베트남, 태국 등 전 세계에 퍼져 있었다. AI 에이전트를 활용한 국적 불명의 공격자가 추적을 방지하기 위해 다양한 국적의 IP로 우회 공격을 감행한 것이다. 금융감독원은 해당 IP 목록을 전 금융권에 배포해 8일까지 자체 점검을 하도록 했다.

오찬종·박성배·연규욱 기자